Chapter 5 / Capítulo 5

Case study / Caso de estudio: Spectertainment

Fuente: CISA Official Review Manual, ISACA. Texto y clave proporcionados por el usuario. Traducción no oficial. Se incluyen las explicaciones completas de todas las alternativas. Los guiones son explicaciones propias.

English: Spectertainment is a company dedicated to the production and distribution of video clips specializing in jazz music. Born in the Internet era, the company has actively supported the use of laptops and tablets, so staff easily work remotely. They can access the company databases through the Internet and provide online information to customers. The decision to support remote work has resulted in an increase in productivity and high morale among employees who are allowed to work up to two days a week from home. Based on written procedures and a training course, employees learn security procedures to avoid the risk of unauthorized access to company data. Employees' access to the company data includes using logon IDs and passwords to the application server through a VPN. Initial passwords are assigned by the security administrator. When the employee logs on for the first time, the system forces a password change to improve confidentiality. Management is currently considering ways to improve security protection for remote access by employees.

Español: Spectertainment se dedica a producir y distribuir videoclips especializados en música jazz. Nacida en la era de Internet, la empresa promueve el uso de computadoras portátiles y tabletas para facilitar el trabajo remoto. El personal accede por Internet a las bases de datos y proporciona información en línea a los clientes. Apoyar el trabajo remoto ha aumentado la productividad y la motivación de los empleados, que pueden trabajar desde casa hasta dos días por semana. Mediante procedimientos escritos y un curso de capacitación, aprenden medidas de seguridad para evitar accesos no autorizados a los datos. Acceden al servidor de aplicaciones mediante VPN utilizando identificadores de inicio de sesión y contraseñas. El administrador de seguridad asigna las contraseñas iniciales y, al iniciar sesión por primera vez, el sistema exige cambiarlas para mejorar la confidencialidad. La dirección estudia cómo mejorar la protección del acceso remoto.

English: Spectertainment asks its IS auditor to review its new VPN implementation to accommodate the increase in remote work. The auditor discovers that many employees are using personal devices to connect to the VPN either while engaged in their remote work or when traveling. There is a remote access policy in place, but it does not specify requirements for personal devices.

Español: Spectertainment solicita al auditor de SI que revise la nueva implementación de VPN destinada al aumento del trabajo remoto. El auditor descubre que muchos empleados se conectan con dispositivos personales al trabajar a distancia o viajar. Existe una política de acceso remoto, pero no especifica requisitos para los dispositivos personales.

Question 1 / Pregunta 1

English: Which of the following would be of MOST concern to an IS auditor reviewing a VPN implementation? Computers on the network that are located:

A. on the enterprise's internal network.

B. at the backup site.

C. in employees' homes.

D. at the enterprise's remote offices.

Español: Al revisar una implementación de VPN, ¿qué computadoras conectadas a la red preocuparían MÁS al auditor de SI? Las ubicadas:

A. En la red interna de la empresa.

B. En el sitio de respaldo.

C. En los hogares de los empleados.

D. En las oficinas remotas de la empresa.

Correct answer / Respuesta correcta: C

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: On an enterprise's internal network, security policies and controls should be in place to detect and halt an outside attack that uses an internal machine as a staging platform. Therefore, this would not be the biggest concern to the IS audit.

Español: En la red interna deberían existir políticas y controles para detectar y detener ataques externos que utilicen un equipo interno como plataforma de ataque. Por ello, no sería la preocupación principal de la auditoría de SI.

B. Incorrect / Incorrecta

English: Computers at the backup site are subject to the corporate security policy and therefore are not high-risk computers.

Español: Las computadoras del sitio de respaldo están sujetas a la política corporativa de seguridad y, por ello, no son equipos de alto riesgo.

C. Correct / Correcta

English: VPN offers a secure connection between the remote PC and the corporate network. VPN does not, however, protect the remote PC from outside attack (such as from the Internet). If the remote PC is compromised, a malicious actor can use the entry point of the compromised remote PC to enter the corporate network (lateral movement).

Español: La VPN ofrece una conexión segura entre el equipo remoto y la red corporativa, pero no protege al equipo remoto contra ataques externos, por ejemplo, desde Internet. Si ese equipo está comprometido, un actor malicioso puede utilizarlo como punto de entrada a la red corporativa mediante movimiento lateral.

D. Incorrect / Incorrecta

English: Computers on the network that are at the enterprise's remote offices, perhaps with IS and security employees who have different ideas about security, are riskier than computers in the main office or backup site, but obviously less risky than home computers.

Español: Los equipos de oficinas remotas, donde quizá el personal de SI y seguridad tenga criterios distintos, presentan más riesgo que los de la sede o el sitio de respaldo, pero claramente menos que los equipos domésticos.

Suggested speaking script / Guion sugerido

English: I choose C because a VPN protects the connection, but an infected home computer can still expose the corporate network.

Español: Elegiría la C porque una VPN protege la conexión, pero un equipo doméstico infectado puede exponer la red corporativa.

Question 2 / Pregunta 2

English: Which of the following levels provides a higher degree of protection in applying access control software to avoid unauthorized access risk?

A. Network and OS level

B. Application level

C. Database level

D. Log file level

Español: ¿Qué nivel ofrece mayor protección al aplicar software de control de acceso para evitar accesos no autorizados?

A. Nivel de red y sistema operativo (SO).

B. Nivel de aplicación.

C. Nivel de base de datos.

D. Nivel de archivo de registro.

Correct answer / Respuesta correcta: A

Explanation of every option / Justificación de cada alternativa

A. Correct / Correcta

English: The greatest degree of protection in applying access control software against internal and external users' unauthorized access is at the network and platform/OS levels. These systems are also referred to as general support systems, and they make up the primary infrastructure on which applications and database systems will reside.

Español: La mayor protección del software de control de acceso frente a accesos no autorizados de usuarios internos y externos se obtiene en los niveles de red y plataforma o sistema operativo. También se denominan sistemas de soporte general y constituyen la infraestructura principal donde residen las aplicaciones y las bases de datos.

B. Incorrect / Incorrecta

English: The application level is part of the infrastructure made up by the general support systems, supported by the network and OS level.

Español: El nivel de aplicación forma parte de la infraestructura de los sistemas de soporte general, sustentada por la red y el sistema operativo.

C. Incorrect / Incorrecta

English: The database level is part of the infrastructure made up by the general support systems, supported by the network and OS level.

Español: El nivel de base de datos forma parte de la infraestructura de los sistemas de soporte general, sustentada por la red y el sistema operativo.

D. Incorrect / Incorrecta

English: The log file level is part of the infrastructure made up by the general support systems, supported by the network and OS level.

Español: El nivel de archivo de registro forma parte de la infraestructura de los sistemas de soporte general, sustentada por la red y el sistema operativo.

Suggested speaking script / Guion sugerido

English: I choose A because the network and operating system provide the foundation for application and database security.

Español: Elegiría la A porque la red y el sistema operativo constituyen la base de la seguridad de aplicaciones y bases de datos.

Question 3 / Pregunta 3

English: When an employee notifies the company of a forgotten password, what should be done FIRST by the security administrator?

A. Allow the system to randomly generate a new password.

B. Verify the user's identification through a challenge/response system.

C. Provide the employee with the default password and explain that it should be changed as soon as possible.

D. Ask the employee to move to the administrator terminal to generate a new password to ensure confidentiality.

Español: Cuando un empleado informa que olvidó su contraseña, ¿qué debe hacer PRIMERO el administrador de seguridad?

A. Permitir que el sistema genere aleatoriamente una nueva contraseña.

B. Verificar la identidad del usuario mediante un sistema de desafío y respuesta.

C. Proporcionar la contraseña predeterminada e indicar que debe cambiarla cuanto antes.

D. Pedir al empleado que vaya al terminal del administrador para generar una nueva contraseña y garantizar su confidencialidad.

Correct answer / Respuesta correcta: B

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: When an employee reports a forgotten password, the security administrator should start a password process generation procedure only after verifying the user's identification using a challenge/response system or similar procedure.

Español: Cuando un empleado informa que olvidó su contraseña, el administrador de seguridad debe iniciar el procedimiento de generación de una contraseña solo después de verificar su identidad mediante un sistema de desafío y respuesta o un procedimiento similar.

B. Correct / Correcta

English: A challenge/response system or similar procedure should be the first step in verifying a user's identity. To verify, it is advised that the security administrator should return the user's call after verifying their extension or calling their supervisor for verification.

Español: Un sistema de desafío y respuesta, o un procedimiento similar, debe ser el primer paso para verificar la identidad del usuario. Se recomienda devolverle la llamada tras verificar su extensión o llamar a su supervisor para confirmarla.

C. Incorrect / Incorrecta

English: Before an employee is provided with a default password, the individual's identity should be verified using a challenge/response system or similar procedure.

Español: Antes de proporcionar una contraseña predeterminada al empleado, debe verificarse su identidad mediante un sistema de desafío y respuesta o un procedimiento similar.

D. Incorrect / Incorrecta

English: Before any further action is taken, the user's identity must be verified. A new password should not be generated until it is confirmed, regardless of the security of the terminal.

Español: Antes de cualquier otra acción debe verificarse la identidad del usuario. No debe generarse una nueva contraseña hasta confirmarla, independientemente de la seguridad del terminal.

Suggested speaking script / Guion sugerido

English: I choose B because identity must be verified before resetting a password.

Español: Elegiría la B porque hay que verificar la identidad antes de restablecer una contraseña.

Question 4 / Pregunta 4

English: Which of the following policies should Spectertainment ensure are in place to address its finding that employees are using personal devices to connect to the VPN?

A. Remote access policy

B. Acceptable use policy

C. Change control policy

D. Access control policy

Español: ¿Qué política debe establecer Spectertainment para abordar el uso de dispositivos personales para conectarse a la VPN?

A. Política de acceso remoto.

B. Política de uso aceptable.

C. Política de control de cambios.

D. Política de control de acceso.

Correct answer / Respuesta correcta: B

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: Spectertainment has a remote access policy in place that outlines the approved methods for remotely connecting to internal resources but does not address the use of personal devices.

Español: Spectertainment dispone de una política de acceso remoto que describe los métodos aprobados para conectarse a recursos internos, pero no aborda los dispositivos personales.

B. Correct / Correcta

English: An acceptable use policy outlines what employees agree to when using and accessing organizational assets. It would confirm whether the use of personal devices is allowed and may also include a Bring Your Own Device (BYOD) policy to further codify their use.

Español: Una política de uso aceptable establece lo que los empleados aceptan al utilizar y acceder a los activos de la organización. Confirmaría si se permite utilizar dispositivos personales y también podría incluir una política de trae tu propio dispositivo (BYOD) para formalizar mejor su uso.

C. Incorrect / Incorrecta

English: Change control policies are required when making changes to IT systems. While some changes may need to be submitted based on any changes needed to support BYOD, it is not the most important control.

Español: Se necesitan políticas de control de cambios al modificar sistemas de TI. Aunque podrían requerirse solicitudes de cambios para admitir BYOD, este no es el control más importante.

D. Incorrect / Incorrecta

English: Access control policies are required to ensure employees understand how to access systems. While changes to the access control policy may need to be made to support BYOD, it is not the most important control.

Español: Se necesitan políticas de control de acceso para que los empleados comprendan cómo acceder a los sistemas. Aunque podrían requerirse cambios para admitir BYOD, este no es el control más importante.

Suggested speaking script / Guion sugerido

English: I choose B because the organization needs clear rules about whether and how personal devices may be used.

Español: Elegiría la B porque la organización necesita reglas claras sobre si se permiten dispositivos personales y cómo utilizarlos.

Question 5 / Pregunta 5

English: Why would Spectertainment choose to support the use of personal devices rather than prohibiting this practice? (Select all that apply.)

A. Increased employee productivity

B. Ease of terminating employee access if necessary

C. Increased cost savings

D. Improved security awareness

Español: ¿Por qué Spectertainment elegiría apoyar el uso de dispositivos personales en lugar de prohibirlo? Seleccione todas las respuestas aplicables.

A. Mayor productividad de los empleados.

B. Facilidad para retirar el acceso de un empleado cuando sea necesario.

C. Mayor ahorro de costos.

D. Mayor concienciación sobre seguridad.

Correct answer / Respuesta correcta: A, C

Explanation of every option / Justificación de cada alternativa

A. Correct / Correcta

English: BYOD policies have shown increased productivity and employee satisfaction.

Español: Las políticas BYOD han demostrado aumentos de productividad y satisfacción de los empleados.

B. Incorrect / Incorrecta

English: BYOD use can make it more difficult to terminate employee access.

Español: El uso de BYOD puede dificultar la retirada del acceso de los empleados.

C. Correct / Correcta

English: Since employees are using their own devices, BYOD can help organizations increase their cost savings.

Español: Como los empleados utilizan sus propios dispositivos, BYOD puede aumentar el ahorro de costos de la organización.

D. Incorrect / Incorrecta

English: The use of BYOD does not indicate that employees have increased awareness of the security risk posed by their use of their personal devices for work.

Español: El uso de BYOD no indica que los empleados tengan mayor conciencia de los riesgos de seguridad derivados de utilizar dispositivos personales para trabajar.

Suggested speaking script / Guion sugerido

English: I choose A and C because using personal devices can increase productivity and reduce equipment costs. It does not automatically improve security awareness.

Español: Elegiría A y C porque utilizar dispositivos propios puede aumentar la productividad y reducir los costos de equipos. No mejora automáticamente la conciencia de seguridad.